

# PromptABI: Static Verification for the Discrete Interface Layer of LLM Systems

PromptABI Contributors

## Abstract

Modern LLM systems fail in places that are not neural: chat templates splice untrusted text into role delimiters, tokenizer metadata changes the strings that grammars actually see, stop sequences fire inside tool arguments, provider adapter chains drop envelope fields, and framework truncation silently drops the evidence a prompt was meant to preserve. These failures are discrete, versioned, and usually present before a single token is generated, yet they are typically discovered through inference-time tests or production incidents.

PromptABI treats this boundary as an application binary interface for prompts. It gives templates, tokenizers, stop policies, tool schemas, provider envelopes, retrieval budgets, multi-agent handoffs, training manifests, and evaluation harnesses a common typed semantics. It then runs bounded symbolic execution, finite-language products, differential replay, and SMT-backed finite contracts to prove one of four useful facts: the interface is safe in the supported fragment, a concrete counterexample exists, the checker must abstain, or a versioned artifact has drifted from a previously verified contract.

The result is a CPU-only verifier that can be run in CI, before fine-tuning, before publishing benchmark scores, or before migrating providers. Its evidence is not a checklist of repository files: diagnostics carry executable witnesses, source spans, token paths, parser states, solver models, replay hashes, and privacy-preserving fingerprints. The reported bug-finding evaluation uses public bug replays that traverse exact pinned production-code excerpts.

## 1 Introduction

The software around an LLM has become a compiler pipeline. A user message is rendered by a chat template, transformed by tokenizer normalization and special token rules, packed into a context window, constrained by a grammar or JSON schema, streamed through stop policies, decoded by a provider adapter, and possibly reused as training or evaluation data. The model may be probabilistic, but this surrounding pipeline is largely deterministic. When it is wrong, the failure is often predictable without running the model.

PromptABI is built on that observation. It verifies the discrete interface layer of LLM systems before inference. The name is intentional: like an ABI for native code, the prompt interface defines what representations cross subsystem boundaries and which invariants downstream components assume. If a prompt template says that user content is data, but renders raw role delimiters inside that content, the ABI is broken. If a tool parser assumes that `</tool_call>` is structural, but a valid string argument may contain that sequence, the ABI is broken. If an evaluation harness scores a model after dropping the system prompt under a framework’s packing policy, the ABI is broken.

This paper presents PromptABI as a programming-languages tool for LLM applications. The focus is not model quality, prompt style, or policy moderation. It is the statically checkable semantics of the artifacts that connect a model to the rest of a program.

**Contributions.** PromptABI contributes:

1. a typed interface model for prompt-system artifacts that are otherwise checked independently or only by example;
2. bounded semantics for chat-template rendering, tokenization, stop reachability, structured outputs, provider migration, context budgets, multi-agent handoffs, training masks, and evaluation harnesses;
3. proof-producing diagnostics that distinguish verified safety, concrete counterexamples, minimal unsatisfiable deployment cores, and honest abstention;
4. a deterministic CLI and embedding API designed for CI and offline use;

5. an evaluation suite whose reported bug-finding results come from public production code in the wild, not synthetic simplifications of those bugs.

## 2 Motivation

LLM applications are commonly tested end-to-end: run a model, inspect a sample, and patch the prompt when behavior looks wrong. That style misses interface bugs for three reasons.

**The bug may be rare under sampling but inevitable in the interface.** If a stop string is allowed inside a valid tool argument, generation may or may not produce it in a test run. The interface, however, admits the bad string regardless of the model distribution.

**The responsible component is often not the model.** Many incidents are caused by a tokenizer revision, chat-template update, provider adapter, streaming parser, framework truncation policy, or evaluation wrapper. These artifacts are versioned software inputs and can be checked like software inputs.

**A passing run is not a proof.** An inference test demonstrates one execution. A verifier can instead enumerate the bounded states of the interface, produce a minimal witness, and record why a claim is valid only in a supported fragment.

PromptABI addresses these gaps by moving checks left: the same artifacts that would be passed to inference are loaded, normalized, and checked before any weights or provider credentials are needed.

## 3 Core Abstraction

**Definition 1** (Prompt interface artifact). *A prompt interface artifact is a discrete, versioned object that influences the string or structured value seen by an LLM subsystem. Examples include chat templates, tokenizer configs, stop policies, JSON schemas, tool definitions, provider request/response envelopes, truncation policies, prompt segments, multi-agent handoff manifests, training manifests, and evaluation manifests.*

**Definition 2** (Prompt ABI). *A prompt ABI is the finite contract induced by a set of prompt interface artifacts: which roles may appear, which strings are data versus control, which tokens are reserved, which regions must survive packing, which grammars can be accepted, which stops may fire, and which structured fields downstream parsers expect.*

PromptABI compiles each artifact into small semantic views. A chat template becomes a bounded set of symbolic render paths and role regions. A tokenizer becomes an encode/normalize/decode relation over finite witnesses. A JSON schema becomes a grammar fragment and representative values. A provider adapter chain becomes a contract over fields, tool-call encodings, streaming chunks, stops, and structured-output modes, with per-hop preservation obligations checked against recorded provider snapshots. A training or evaluation manifest becomes a set of finite obligations about roles, masks, preserved context, answer schemas, and private fields.

A multi-agent handoff manifest becomes a concrete edge contract between named agents. Each agent declares accepted roles, emitted roles, required provenance fields, schema-level type expectations, and forbidden control markers. PromptABI replays the actual payload crossing the edge and emits a handoff witness when the target rejects the role, a policy hash or case identifier is dropped, a field changes JSON type, or unescaped tool/template control text crosses from one agent’s output into another agent’s input.

The tool deliberately does not claim to model arbitrary Python, arbitrary Jinja, or arbitrary parser code. Its supported fragments are explicit. Outside them, PromptABI reports abstention instead of returning a false proof.

## 4 Formal Verification Core

PromptABI’s checkers share a common pattern:

1. load typed artifacts with source spans, hashes, and version metadata;
2. compile them to bounded semantic objects;

3. run a product, symbolic execution, differential replay, or SMT query;
4. emit either a proof summary, a concrete witness, or an abstention.

## 4.1 Role Boundaries

The role-boundary checker symbolically executes supported chat-template fragments. It partitions each rendered path into structural regions such as system, user, assistant, tool, developer, and function. It then asks whether an attacker-controlled field can render a structural marker: role headers, special tokens, assistant prefixes, tool delimiters, markdown fences, or provider sentinels.

For example, a template that renders

```
'<|user|>\n' + message['content'] + '<|end|>\n'
```

without escaping permits user content to contain `<|system|>` or `<|end|>` as literal control text. PromptABI reports the input field, the marker, the rendered excerpt, the tokenized representation, and the exact offset of the forged boundary.

## 4.2 Stops and Structured Outputs

Stop policies are safe only relative to the language of outputs they interrupt. PromptABI builds bounded structured-output regions for JSON strings, tool arguments, XML-like tool calls, markdown fences, and provider tool-call envelopes. It then checks whether a configured stop sequence can occur before a valid structured output is complete.

The witness records the stop, the valid full output, the prefix returned after truncation, the parser state at the firing point, and the malformed or prematurely accepted structure a downstream parser would receive.

## 4.3 Tokenizers, Grammars, and Streaming Parsers

Tokenizer bugs often arise from mismatches between text-level constraints and token-level behavior. PromptABI can compare tokenizer revisions, detect drift in special-token IDs and normalization, and form bounded products between a tokenizer relation and a grammar. This exposes empty products, ambiguous token paths, decoded-text conflicts, whitespace aliases, Unicode normalization surprises, and added-token interactions.

Streaming parsers are first-class products as well. A provider may split a tool call, JSON object, or structured response across arbitrary chunks, while the application parser treats some states as protected data regions. PromptABI models the chunked parser as a bounded deterministic state machine and composes it with a substring monitor DFA. The command `promptabi streaming-parser -monitor '</tool_call>'` proves whether a literal can be observed while the parser is inside a JSON string, and returns the chunk index, event index, parser state, and excerpt when it can. This makes streaming stop/tool-parser bugs reproducible without calling a provider.

## 4.4 Budgets, Training, and Evaluation

Context windows are treated as finite packing problems. PromptABI combines declared segments, tokenizer-derived or declared token counts, output reserves, tool overhead, generation prompts, and framework truncation policies to prove whether required regions survive. The same machinery applies to RAG citations, training masks, supervised target roles, DPO/RLHF pair consistency, and evaluation harness prompts. The RAG model now composes retrieved chunks with the tool schemas that consume them: a chunk can declare the tool argument fields it will supply, PromptABI infers bounded rendered facts such as content, document IDs, and citations, and the verifier compares those facts with the normalized OpenAI/Anthropic/MCP-style tool schema under the same framework truncation policy. It therefore distinguishes a valid chunk that preserves all required tool arguments from a chunk whose citation is dropped, whose `order_id` is never rendered, or whose metadata would be rejected by a closed JSON Schema. A benchmark score should not be trusted if the grader rubric, answer schema, system prompt, private answer key, or tool-consuming retrieval evidence can be dropped or exposed by the interface.

## 4.5 Provider Migration

Provider migration is checked as a contract comparison, not as string matching. PromptABI compares request and response surfaces: tool-call IDs, JSON-object versus JSON-string arguments, parallel-call support, streaming chunk assembly, stop semantics, context limits, structured-output modes, and error envelopes. For adapter chains,

it additionally proves that declared provider-envelope obligations survive every hop: the analyzer checks the ordered chain, the adapter’s own preservation declaration, and the target provider’s recorded surface. A LiteLLM-to-Azure OpenAI chain can therefore be proven equivalent for OpenAI-style tool envelopes, while a LiteLLM-to-Anthropic chain emits concrete losses for response fields, JSON-string arguments, streaming fragments, stops, and structured-output modes. The output is a set of migration diagnostics with concrete fields and suggested safe fixes.

## 5 What the Tool Can Do

Table 1 summarizes the main classes of checks. The table is organized by programmer need rather than by implementation module.

| Need                                       | PromptABI check                                                                                                      | Evidence produced                                                                          |
|--------------------------------------------|----------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------|
| Prevent prompt control injection           | Role-boundary non-forgeability over bounded template paths                                                           | Forged marker, input field, rendered region, token evidence                                |
| Avoid premature parser truncation          | Stop-overreachability over schemas, tools, and provider envelopes                                                    | Stop firing point, parser state, malformed prefix                                          |
| Trust constrained decoding                 | Tokenizer $\times$ grammar emptiness and ambiguity checks                                                            | Token path, decoded text, grammar state, minimal string                                    |
| Migrate providers safely                   | Provider, streaming, and adapter-chain envelope preservation                                                         | Lost field, changed encoding, broken hop, response-shape witness                           |
| Protect RAG, training, and eval invariants | Context-budget, RAG/tool-schema, mask, role, and private-field obligations                                           | Survival proof, missing tool argument, dropped-region witness, finite assignment           |
| Debug multi-agent workflows                | Handoff contracts over roles, provenance fields, schema types, and control markers                                   | Source/target edge, offending payload field, rendered handoff excerpt, minimal adapter fix |
| Maintain reproducible CI                   | Lockfiles, inherited config lineage, signed bundles, replayable solver certificates, sliced products                 | Artifact hash, diagnostic fingerprint, replay hash, minimal artifact cover                 |
| Scale monorepo verification                | Incremental plans with cache-soundness certificates                                                                  | Dependency cut, current cache fingerprint, relevant artifact hashes                        |
| Block stale deploys                        | Kubernetes, Terraform, GitHub Environment, and release-system gates                                                  | Current bundle hash, reproducibility hash, gate manifest                                   |
| Report live contract identity              | Runtime attestation hooks for services exposing verified prompt, tokenizer, template, schema, and provider contracts | Service-scoped bundle hash, per-contract hashes, env/HTTP/Kubernetes/OTel hooks            |

Table 1: PromptABI capabilities stated as user-facing verification needs.

## 6 How It Proves Things

PromptABI uses proof techniques that match the artifact being checked. It does not use one universal solver for every problem.

**Bounded symbolic execution.** For supported chat-template fragments, PromptABI enumerates bounded control-flow paths and loop counts. Each path is a sequence of symbolic segments annotated with role ownership and source expressions. A finding is constructed only when a user-controlled expression is in a region whose control markers are known.

**Finite-language products.** Tokenizers, grammars, and parser fragments are compiled to finite relations for the witnesses under consideration. Products and projections answer emptiness, ambiguity, and reachability questions

with concrete paths.

**Counterexample slicing.** For composed products that span templates, tokenizers, providers, policies, and parsers, PromptABI can compute the minimum-cost artifact slice that still covers the failing product facts. The slicer exhaustively searches the bounded product, records omitted artifacts and cut dependency edges, and emits a witness whose certificate distinguishes a necessary cross-artifact explanation from incidental configuration noise.

**Concrete handoff replay.** Multi-agent frameworks often convert one agent’s answer into another agent’s input through informal dictionaries. PromptABI treats these dictionaries as interface artifacts. The handoff checker does not inspect arbitrary agent code; instead, it verifies a concrete manifest extracted from or checked into the application: source agent, target agent, payload role, payload fields, required provenance, target field types, and forbidden markers. The witness is therefore directly replayable: select the edge, replay the payload contract, point to the exact role/field/marker that violates the target contract, and suggest the smallest adapter such as role normalization, JSON encoding, or provenance preservation.

**SMT-backed finite contracts.** Static contracts that combine budgets, roles, stops, masks, and provider facts are lowered to finite SMT obligations. Solver models become counterexamples; unsatisfiable obligations become proof summaries. Reduced solver-replay files allow a result to be rerun without the original private artifacts.

**Inherited proof obligations.** Large deployments share base PromptABI configs for organization policies, common artifacts, and solver budgets, then let services extend them with local prompts or tool schemas. PromptABI resolves every inherited config in its own directory, merges typed artifacts rather than raw JSON, detects cycles, and records which file contributed each proof obligation. Static-contract findings include this lineage, so an unsafe budget witness can say that the prompt came from a service config while the finite context bound came from a platform base config.

**Incremental cache certificates.** Changed-artifact verification in monorepos is safe only if skipped checks are separated from the changed dependency cut and the reused cache entry is addressed by the current inputs. PromptABI now emits an executable cache-soundness certificate for each reused check: it rechecks the planner’s skipped set against declared artifact kinds and **after** edges, rejects remote or unknown dependencies that require a full run, and compares the lookup key with a SHA-256 fingerprint of the current config, relevant loaded artifact hashes, and dependency metadata. A stale or under-specified cache entry is recomputed rather than reported as safe.

**Differential replay.** Where a library is the specification, PromptABI runs small differential cases against real tokenizer/template/parser behavior. This catches divergence between the local abstraction and the implementation developers deploy.

**Fail-closed abstention.** If a construct is outside the supported fragment, a dependency is missing, a schema cannot be modeled, or a source-derived value cannot be recovered, PromptABI reports that fact. It does not silently turn an unsupported case into a safe result.

## 6.1 The Solver-Trust Layer

A sound verifier is only as credible as the evidence that its own decision procedure is correct, deterministic, and honestly scoped. PromptABI therefore ships a self-certifying solver-trust layer that treats the solver as an artifact to be verified rather than an oracle to be trusted.

**Cross-strategy portfolio replay.** Every finite obligation can be discharged through a portfolio of independent strategies—the Z3 backend and an exhaustive finite-enumeration backend—and the layer requires that all strategies that terminate *agree* on the verdict before any safety claim is emitted. The portfolio result is replayable: re-running the recorded lemmas reproduces the same per-strategy verdicts bit-for-bit, so a proof can be audited without the original private artifacts.

**Mechanized minimal encodings and conformance suites.** The supported fragment is pinned down by a published corpus of *smallest* encodings—for each expression construct, the minimal finite problem that exercises it together with the verdict it must yield. Each encoding is mechanized on both backends, and a separate *solver-fragment conformance suite* labels representative satisfiable, unsatisfiable, and out-of-fragment instances. A new solver release, an alternative engine, or a downstream re-implementation is certified by passing the suite; the same suite is regression protection for PromptABI itself.

**Proof-carrying caches and lemma reuse.** Cached solver results carry their evidence: a satisfying model for SAT entries and an unsat core for UNSAT entries. Every cache hit is re-validated against the carried proof and rejected if the entry has been tampered with, so reuse never weakens soundness. A complementary lemma cache memoizes reusable sub-obligations across runs under the same fingerprinting discipline.

**Witnesses, certificates, and source spans.** SMT counterexamples are minimized into human-readable witnesses that drop structurally irrelevant variables and report the flexible value ranges that still violate the contract, and each counterexample variable is mapped back to its originating source span. Abstentions are themselves certified: an abstention certificate classifies a refused formula against the supported node and domain registries, naming every out-of-fragment construct, which turns “the solver gave up” into an auditable statement rather than a silent gap.

**Graceful degradation under resource limits.** Because enumeration is exponential in the worst case, the layer profiles each problem across a timeout ladder and certifies *degradation soundness*: under tighter budgets the solver may return fewer conclusive verdicts, but no conclusive verdict it does return may ever contradict the ground truth computed under a generous budget. Solver-version gates and migration interpolants extend the same discipline across provider and solver upgrades.

**Capability signatures for reusable packs.** The same canonicalization machinery is applied above the solver. A reusable prompt pack is distilled into an order-independent capability signature—its exported templates, expected roles, tool schemas, stop policies, and supported model families, plus a stable digest—so a consumer’s requirements can be matched against a pack by set containment, and an upgrade can be certified backward compatible (or flagged as a silently breaking “patch” release) by differencing two signatures.

**Theorem 1** (Bounded counterexample soundness). *For a supported checker fragment, every unsafe PromptABI diagnostic contains a witness that is accepted by the artifact semantics used by that checker and violates the stated interface obligation.*

*Proof sketch.* Each checker constructs diagnostics from semantic objects, not from ad-hoc strings. The template checker builds a witness from an enumerated symbolic path, role region, and input expression. The stop checker substitutes the stop into a valid structured-output witness and records the parser state at truncation. The grammar/tokenizer check records a concrete token path through the product. The SMT layer records the satisfying assignment or unsat result for the lowered finite obligation. Tests replay these witnesses through the same checker semantics and, where applicable, real library adapters.  $\square$

**Theorem 2** (Honest supported-fragment boundary). *PromptABI’s successful safety claims are scoped to explicit supported fragments; inputs outside those fragments produce abstentions or setup failures rather than passing diagnostics.*

*Proof sketch.* Artifact loaders and checkers validate dialects, parser support, dependency availability, schema fragments, and source-derived replay assumptions before claiming success. Unsupported constructs are recorded in the diagnostic model, and release tests require abstentions to remain visible.  $\square$

**Theorem 3** (Incremental cache reuse soundness). *Under complete checker dependency metadata, a PromptABI incremental run reuses diagnostics for a skipped check only when no changed artifact kind, selected prerequisite, selected dependent, remote dependency, or stale cache fingerprint can affect that check.*

*Proof sketch.* The planner maps changed paths to typed artifact kinds and closes the selected set over direct dependency edges. Before a cache hit is trusted, an `IncrementalCacheCertificate` independently checks that the skipped check was requested, the run was not forced full, changed kinds are disjoint from the check’s declared artifact kinds, selected checks do not cross the prerequisite or dependent cut, and the cache lookup key equals the fingerprint recomputed from the current config, relevant artifacts, and dependency metadata. Any failed obligation causes recomputation.  $\square$

**Theorem 4** (Cross-strategy verdict agreement). *For a supported finite obligation, PromptABI emits a verdict only when every portfolio strategy that terminates returns the same verdict, and any conclusive verdict produced under a reduced time budget equals the verdict produced under a generous one.*

*Proof sketch.* The portfolio runs the Z3 backend and an exhaustive finite-enumeration backend on the identical lowered problem. The enumeration backend is a decision procedure over the finite domain product, so when it terminates it is exact; a recorded disagreement is therefore surfaced as a finding rather than a verdict. The degradation profiler computes a ground-truth verdict under a generous budget and compares every timeout-laddered run against it, asserting that timing out yields an inconclusive status that is never reported as a safe or unsafe claim.  $\square$

## 7 Executable Metatheory

The check families above are grounded in a small core calculus for prompt assembly whose metatheory PromptABI *mechanizes in the executable sense*: every theorem is stated precisely and then discharged by exhaustive, bounded enumeration over the production implementation (`promptabi.prompt_calculus`), in the style of executable semantics frameworks such as PLT Redex and randomized proof tools such as QuickChick. A claim is trusted only after an independent reference predicate confirms it on every element of a finite, explicitly bounded domain. The full development is reproducible with one command, `promptabi metatheory`, and rendered as a standalone formal appendix with `promptabi metatheory --appendix`.

**The calculus.** Terms are  $t ::= \text{Lit } s \mid \text{Data } s \mid \text{Esc } t \mid \text{Seg } r t \mid \text{Concat } t t$ , where `Lit` is trusted, developer-authored control text (free of delimiter characters), `Data` is untrusted input, `Esc` is a sanitizer, and `Seg`  $r$  wraps a body in the structural role delimiters  $\langle r \rangle \cdots \langle \text{end} \rangle$ . A small-step machine reduces configurations to a provenance-annotated character stream; a denotational renderer gives the reference meaning.

**Theorems.** The mechanized development covers fourteen theorems, including: (i) the small-step relation is a deterministic total function on non-final configurations, every term normalizes, and its normal form equals the denotational renderer (*adequacy*); (ii) *type soundness / role non-forgeability*: if  $\vdash t : \text{control}$  then no adversarial data assignment produces a control-delimiter occurrence that includes a data-provenance character, and the rejected (ill-typed) programs are exhibited as genuine forgery witnesses; (iii) contextual equivalence is an equivalence relation and a *congruence*; (iv) the stop policy is a *denotational truncation* function equal to the operational scanner and always a stop-free prefix; (v) the structured-output schema checker is *sound and complete* against an independent reference acceptor; (vi) the decidable grammar-backend fragment is a *down-closed* region of the feature lattice, characterized exactly by its maximal elements; (vii) a *noninterference* theorem: the control skeleton is invariant under all substitutions of data leaves; (viii) capability-negotiation fallback is *monotone* and order-preserving; (ix) tool-call accounting is a *session-type* discipline whose typed traces are exactly the balanced ones; (x) safe migration dry-run patches *preserve* request well-formedness; (xi) provider-contract refinement is a *preorder*; (xii) conformance is *compositional* over prompt-pack composition; and (xiii) prompt-interface drift forms an *ultrametric*. The core role-non-forgeability proposition is additionally mirrored in a Lean 4 source artifact for the formal appendix.

**Theorem 5** (Role non-forgeability). *For every well-typed term  $t$  (every `Data` leaf guarded by `Esc`) and every adversarial data assignment, the rendered prompt contains no control-delimiter occurrence spanning any data-provenance character.*

*Proof.* The sanitizer denotation removes data “<” characters and trusted literals contain no “<”; hence every delimiter occurrence’s leading character is structural control text emitted atomically by `Seg`. The PromptABI harness discharges the proposition by enumerating all well-typed terms up to depth two over an adversarial data alphabet that includes every whole delimiter, checking the independent forgery predicate on each, and separately exhibiting ill-typed forgery witnesses so the type system is shown to be meaningful rather than vacuous.  $\square$

Across the suite, PromptABI checks tens of thousands of bounded instances with zero counterexamples for every proved obligation; the per-theorem domain sizes and pass/fail status are emitted as stable JSON for the artifact appendix.

## 8 Implementation

PromptABI is a Python tool with a deterministic command-line interface and an embedding API. The implementation is organized around typed artifacts and typed diagnostics rather than around particular frameworks. The same verification result can be rendered as text, JSON, SARIF, GitHub annotations, HTML reports, signed bundles, or downstream integration payloads.

The CLI is intentionally CPU-only for the checks described here. That property is important: users can run PromptABI in pull requests, air-gapped builds, pre-commit hooks, release gates, fine-tuning preflight jobs, benchmark publication workflows, and provider migration reviews without model weights or provider credentials.

Privacy is part of the implementation contract. Diagnostics can expose exact structural witnesses for public fixtures, but private workflows can choose position-preserving redaction, hash-only evidence, or structural summaries while preserving stable fingerprints.



## 9 Deployed Workflows

PromptABI is intentionally presented as a tool, not only as a library of analyses. The implementation ships multiple workflows that exercise the same artifact semantics from different operational positions.

**Pull-request verification.** The core command is `promptabi verify`. It discovers or accepts a configuration file, loads typed artifacts, applies policy packs, runs selected checks, and emits deterministic text, JSON, SARIF, GitHub annotations, or static HTML. CI usage can require a lockfile, compare changed artifacts only, and upload SARIF without contacting an LLM provider. Changed-artifact mode now attaches cache-soundness proof obligations to every reused diagnostic, so a monorepo gate can distinguish a proved reuse from a forced recomputation.

**Deployment gates.** `promptabi deployment-gates` regenerates signed verification-bundle evidence and emits enforcement examples for Kubernetes admission policies, Terraform preconditions, GitHub protected environments, and internal release systems. Each example binds deployment metadata to the current bundle hash, reproducibility hash, signing-key identifier, and verification gate status.

**Runtime attestation.** `promptabi runtime-attestation` produces the complementary service-side payload: a process can report which verified prompt segments, tokenizers, chat templates, schemas, and provider contracts it is running. The output includes a deterministic manifest plus environment-file, HTTP JSON, Kubernetes annotation, and OpenTelemetry attribute hooks. Each hook carries the current signed bundle hash, reproducibility hash, signing-key identifier, service name, environment, and stable per-contract hashes, so inventory systems can answer “what PromptABI contract is live here?” without reading private prompt contents. Drift alarms are intentionally a separate policy layer; this workflow is the trustworthy self-reporting primitive.

**Runtime drift alarms.** `promptabi runtime-alarms` consumes that self-report and compares it with the newest lockfile, runtime policy pack, corpus baseline, and known-bad artifact manifest. This separates service inventory from enforcement: a running service can expose only non-content hashes and version metadata, while the platform decides whether the live contract has drifted from reviewed artifacts, violates approved signing-key or environment policy, fell behind corpus baselines, or matches a known-bad tokenizer, schema, provider, or prompt version.

**Training preflight.** `promptabi verify-training` builds or loads a training manifest and checks role layouts, tokenizer/template consistency, packing windows, loss masks, target spans, DPO/RLHF pair structure, data-loader adapters, and redaction constraints. It is designed to run before a costly fine-tuning job starts.

**Prompt-pack governance.** Reusable prompts are treated as packages with exported templates, roles, tool schemas, stops, supported model families, lockfiles, upgrade checks, signed provenance, public registry metadata, and offline mirrors. A consuming application can reuse package-level proofs and then add local context, RAG chunks, tools, or truncation rules. A monotonicity certificate strengthens ordinary upgrade checks: existing templates, role obligations, required tools, stop contracts, diagnostics, and model-family support are compared against a baseline lockfile, while only append-only optional extensions are accepted. The newest composition layer also checks exported chat-template markers against the configured tokenizer: a prompt pack can prove that its structural markers have bounded tokenizer evidence, or fail with a concrete user-content witness when a downstream tokenizer admits a control token that the pack did not reserve.

**Multi-agent handoff witnesses.** `promptabi handoff-witness` verifies concrete handoff manifests for agent graphs whose framework code dynamically routes work between specialized agents. For each edge, the manifest declares the source and target contracts and the payload that crosses the boundary. The checker emits ordinary PromptABI witness traces for rejected roles, missing provenance fields, JSON type drift, and unescaped control markers. A support escalation example demonstrates all four: a triage agent forwards assistant text to a refund agent that accepts only tool payloads, drops the policy hash, serializes a numeric refund as a string, and passes an unescaped `</tool_call>` sentinel in content. The result is a small, reproducible witness that an orchestration bug exists before any agent loop runs.

**Debugging and education.** `promptabi explain` expands one diagnostic into artifact snippets, formal property, witness, likely symptom, and fix. `promptabi proofs` emits proof sketches and executable notebook artifacts for the core families: role-boundary non-forgeability, stop reachability, grammar emptiness, budget survival, and training-mask alignment.

**Release and maintainer workflows.** The repository includes compatibility audits, corpus verification, maintainer refresh, LTS planning, release readiness, theorem-to-test traceability, and benchmark leaderboards. These are not paper-only scripts; they are CLI commands that run against repository fixtures and examples.

## 10 Platform Integration Payloads

The stable integration API emits a single platform-facing report whose surfaces are specialized for downstream systems.

| Surface           | Payload                                                    | Intended consumer                                        |
|-------------------|------------------------------------------------------------|----------------------------------------------------------|
| CI provider       | exit code, SARIF, annotations, runtime counts              | GitHub Actions, Buildkite, Jenkins, internal merge gates |
| IDE extension     | document-grouped spans, rule IDs, suggestions              | VS Code, language-server bridges, editor plugins         |
| Dataset platform  | training/eval artifacts and private-field-safe diagnostics | fine-tuning and benchmark pipelines                      |
| Model registry    | provenance, reproducibility hash, optional signed bundle   | HF Hub, MLflow-style stores, internal registries         |
| Internal platform | policy, guarantee mode, privacy, risk rollups              | enterprise AI platforms and audit dashboards             |

Table 2: Downstream integration surfaces produced by the same verification run.

The key engineering decision is that these payloads are stable and non-content-first. They preserve hashes, fingerprints, offsets, modes, and artifact summaries; they do not require platform teams to parse human text or copy private prompt contents into central services.

## 11 Model Registry Gates

Model publication is a natural place to enforce prompt-interface evidence: registry promotion already records model IDs, aliases, stages, lineage, and artifacts. PromptABI adds a deterministic publication manifest for four common registry families:

1. Hugging Face Hub model repositories and model-card metadata;
2. internal registries with access-controlled attestation storage;
3. MLflow-style registered models and artifact directories;
4. generic artifact repositories such as OCI, S3, or Artifactory layouts.

The command

```
promptabi model-registry -config examples/model-registries/promptabi.json -targets examples/model-registri
```

builds a manifest containing the registry evidence surface, target-specific publication commands, signed bundle metadata, reproducibility hash, diagnostic fingerprints, and artifact summaries. A deployment system can require `ok: true` before changing a model alias to production.

This matters because model registries often track weights but not the prompt ABI that makes those weights usable. The same base model can be safe for one template and unsafe for another; one provider adapter may serialize tools differently from another; one tokenizer revision may invalidate an accepted structured-output grammar. PromptABI attaches evidence to the published model version without embedding private prompts or calling the model.

## 12 Deployment Gates

Deployment systems need a narrower contract than model registries: they need to know whether the artifact about to run is still the one PromptABI verified. The deployment-gate workflow builds that contract from the same signed bundle payload used for audit trails. The command

```
promptabi deployment-gates -config examples/minimal/promptabi.json -output-dir /tmp/gates
```

emits four executable gate examples plus a deterministic manifest. The Kubernetes example is a **ValidatingAdmissionPolicy** requiring deployment annotations for the current bundle and reproducibility hashes. The Terraform example uses **terraform\_data** preconditions so plan/apply fails on stale PromptABI metadata. The GitHub Environments example regenerates the gate manifest inside a protected environment job and checks hashes before approval. The internal release-system example is a compact JSON policy for release orchestrators that compare declared deployment metadata with signed PromptABI evidence.

These are intentionally examples, not a new trust root. The trust root remains the local signing key and the reproducible bundle payload: config hash, artifact hashes, diagnostic fingerprints, lockfile state, and witness hashes. Deployment controllers can be simple because they only compare stable hashes and gate status. If the prompt template, tokenizer, schema, provider fixture, policy pack, or diagnostics drift, the bundle hash changes and the deployment gate fails closed.

## 13 Enterprise and Air-Gapped Operation

The repository contains enterprise features that are unusual for research verification prototypes. Policy packs can require checks, set severity thresholds, select supported fragments, tune solver timeouts, disable local summary files, and require approved provider fixtures. Access-control metadata records approved private artifact indexes, prompt packs, policy packs, and audit-bundle retention expectations.

Air-gapped usage is first-class. PromptABI can run with local fixtures, vendored wheels, vendored Z3 binaries or wheels, offline seed corpora, local prompt-pack mirrors, and no provider network calls. Signed verification bundles store enough reproducibility metadata for an audit trail: config hash, lockfile state, artifact hashes, diagnostic fingerprints, witness hashes, solver metadata, and optional non-sensitive excerpts.

The resulting operational posture is conservative. The verifier does not need model weights, does not need prompt text to leave the repository, and does not send telemetry. Teams that need strict privacy can emit hash-only witnesses and still keep stable diagnostic fingerprints for trend reports and suppressions.

## 14 Prompt-Pack Supply-Chain Trust

Reusable prompt packs are dependencies, and dependencies need a supply chain that is as auditable as the artifacts themselves. PromptABI distills each pack into a canonical *capability signature*—order-independent sets of the templates, roles, tools, stop policies, and model families it promises—and builds a trust layer on top of that signature, where every badge is backed by a machine-checkable proof rather than a claim.

A registry resolves the full transitive dependency closure of a root pack, pins every reachable version to a content digest, and refuses to emit a lockfile when a dependency is missing, when two paths demand conflicting versions, or when the graph contains a cycle. The resulting lockfile is summarised by a single Merkle-style root digest, so re-verification catches a tampered pin, a drifted registry, or an understated closure. Publication events flow into an append-only, hash-chained *transparency log*; because the chain is deterministic, an auditor can be handed a minimal inclusion proof for one entry and reconstruct the committed head without seeing the rest of the private log.

Policy is inherited monotonically. Each layer—an organisation base pack, a team extension, a project—declares mandatory tools, banned roles, permitted model families, and per-rule diagnostic-severity floors; the verifier proves that a descendant only ever *tightens* an inherited constraint, naming any tool dropped, role re-permitted, family widened, or floor lowered. Exported roles are proven non-forgable: given a pack’s role markers and its consumer input channels, PromptABI checks that every privileged marker is neutralised in every untrusted channel—by exact-string escaping or structural isolation—and emits a concrete forging witness for any gap. Shipped examples are certified against the pack’s real artifact, so an example cannot target an unsupported family or call an undeclared tool. Finally, lifecycle metadata (release, LTS, deprecation, end-of-life, successor) is validated for coherence and resolved against a reference date, and offline consumers install from HMAC-signed mirrors whose manifest and per-artifact digests are verifiable with no network.

These guarantees compose into four cumulative *trust tiers* (Table 3); a higher badge strictly implies every proof the lower badge required, and the assessor reports exactly which evidence is still missing for the next tier, so a label can never outrun its proofs.

| Tier      | Evidence required (cumulative)                                               |
|-----------|------------------------------------------------------------------------------|
| Community | capability signature; verified transitive lockfile                           |
| Verified  | transparency-log inclusion; sound policy inheritance; one independent review |
| Certified | certified examples; signed offline mirror; two independent reviews           |

Table 3: Evidence-backed marketplace trust tiers; each tier subsumes the proofs of those below it.

## 15 SDKs and Stable Public API

PromptABI exposes two layers for downstream code. The Python package exports typed artifacts, diagnostics, sessions, reports, lockfiles, bundles, integration payloads, model-registry publication helpers, and renderers. Public API metadata is generated by `promptabi api-docs`; stable symbols carry a compatibility promise for the 1.x line, while provisional symbols remain importable for experimentation.

For non-Python consumers, the repository ships thin TypeScript, Go, and Rust clients. They intentionally do not reimplement PromptABI's analyses. Instead, they read stable payloads: diagnostic JSON, integration reports, lockfiles, and signed verification bundles. This is the right boundary for CI providers, IDEs, model registries, dataset platforms, and internal AI platforms: verification stays in one implementation, while consumers get stable schemas.

| Client     | Reads                                    | Typical use                                         |
|------------|------------------------------------------|-----------------------------------------------------|
| TypeScript | diagnostics, reports, lockfiles, bundles | web dashboards, VS Code bridges, registry frontends |
| Go         | diagnostics, reports, lockfiles, bundles | CI runners and platform controllers                 |
| Rust       | diagnostics, reports, lockfiles, bundles | high-assurance release gates and local tools        |

Table 4: Thin SDKs consume stable evidence instead of duplicating checks.



## 16 Examples as Executable Specifications

The repository examples are designed to be executable specifications. The minimal example demonstrates config loading, artifact hashing, schema and tool metadata, and deterministic diagnostics. Role-boundary examples show a buggy ChatML-style template and a fixed escaped version. Stop-policy examples exercise vLLM-style stop traces. Token-budget examples demonstrate must-survive segments, reserved output budgets, and framework truncation behavior.

End-to-end examples cover tool calling, JSON structured output, RAG truncation, provider migration, training alignment, and a GPU-free training quickstart. Each pair contains the application symptom, a buggy PromptABI config, and a fixed config. The examples are intentionally small enough for CI but grounded in real interfaces: provider JSON, tool schemas, tokenizer configs, training manifests, and application parsers.

The model-registry examples extend this pattern to deployment. They show how the same verification result can be attached to a Hugging Face Hub model, an internal registry record, an MLflow-style registered model, or a generic artifact repository. The example target manifest is executable through `promptabi model-registry`; tests assert that all four publication families are present and that the evidence is signed and reproducible.

## 17 Composable Prompt-Pack Extensions

The supply-chain trust layer (§14) establishes that a pack is what it claims to be; a second layer establishes that a pack *keeps behaving* as it is extended, certified, and depended upon. PromptABI treats a prompt pack as a versioned interface and equips it with the same machinery a software package ecosystem provides, every guarantee backed by a checkable witness.

**Differential fixtures and semantic versioning.** Each pack carries golden *differential fixtures*: input/output pairs that pin observable behaviour. When a new revision is proposed, PromptABI replays the fixtures and classifies the diff as a patch, minor, or breaking change, then checks that the declared semantic-version bump is no smaller than the observed change. A pack that silently breaks a fixture while advertising a patch release is rejected with the offending fixture named. Override-safety analysis proves that a downstream override only narrows the base behaviour—it may restrict a tool or tighten a stop policy, never reintroduce a control marker into a data channel.

**Schema certification and advisories.** Structured-output contracts shipped by a pack are certified against the supported JSON-schema fragment, so a pack cannot promise a constraint the runtime grammar layer cannot enforce; any unsupported construct is surfaced as an abstention with its JSON path. A machine-readable *advisory* format lets a pack publisher announce a defect (“revisions < 1.4.0 leak the system role through the `context` channel”), and consumers resolve advisories against their pinned version using the same version algebra that governs the semver gate.

**Retrieval, curriculum, and packing extension points.** Packs that feed retrieval-augmented and training pipelines expose declared extension points. PromptABI verifies that retrieved context is injected only into data regions—a placeholder that lands inside a role header is flagged as an in-control-region hazard—and that multi-epoch packing and curriculum schedules preserve the invariants (no example crosses a document boundary, no private field survives a packing transform, curriculum drift between epochs stays within a declared tolerance).

**Certification, provenance, and interoperability.** A third party can issue an HMAC-signed certification over a demo pack’s canonical bytes; the signature binds the pack identity, the model-registry provenance record, and the certifier, so a forged or post-dated certificate fails verification offline. An *interoperability leaderboard* aggregates, per pack, which providers satisfy its declared interface, turning “works on my model” into a reproducible matrix. Together these checks let a marketplace publish packs whose every label—version, schema, advisory status, certification—is an evidence-backed claim rather than documentation.

## 18 Training-Data Interface Contracts

Fine-tuning and preference optimisation pipelines are prompt-interface programs too, and their failures are silent: a mislabelled loss mask, a leaked judge prompt, or a tokenizer misalignment degrades a model without raising an error. PromptABI extends its static-verification discipline across the dataset boundary with a contract for every stage of the data pipeline.

**Masks, targets, and tokenizer alignment.** A training example declares which spans are supervised; PromptABI certifies that the loss mask covers exactly the intended target spans, that no prompt token is accidentally supervised, and that target spans survive tokenization—the character spans and token spans must align under the declared tokenizer, or the example is rejected with the misaligned region highlighted. Streaming shard replay proves that a sharded, shuffled corpus reconstructs the same multiset of examples regardless of shard order, so a training run is reproducible from its manifest.

**Privacy, leakage, and redaction.** Judge prompts used in RLHF must not embed evaluation answers; preference pairs must be *symmetric* (swapping the chosen and rejected responses must flip, not corrupt, the label). PromptABI checks both, and proves that benchmark contamination is absent by testing the training corpus against held-out evaluation fingerprints. Redaction invariance is proven through the full transform stack: a field marked private must remain redacted after every packing, templating, and multimodal-placeholder substitution, with a concrete witness for any leak.

**Cards, gates, and suites.** Each dataset carries machine-validated card metadata; a conformance badge attests that a loader honours the declared contract; training-drift alarms fire when a refreshed corpus diverges from its baseline beyond tolerance; and a fine-tune manifest is gated against the model registry so an artifact cannot be promoted on data that failed its contract. A published training-contract benchmark suite exercises ten end-to-end scenarios against the real analyzers, so the guarantees are demonstrated, not merely asserted.

## 19 Provider-Contract Conformance

The discrete interface a developer programs against is ultimately implemented by a provider, and “OpenAI-compatible” is a claim, not a proof. PromptABI’s final layer makes provider behaviour accountable through a shared, replayable contract and a conformance regime built on top of it.

**An open test-vector format.** A *provider test vector* is a declarative artifact—messages, the provider-agnostic obligations the response must satisfy (role boundaries non-forgeable, declared stop policy terminates, structured output validates, tool calls well-formed, error envelope conformant), and the salient features of an acceptable response. Vectors have a canonical serialization and a stable content digest, so a suite authored once can be replayed against any adapter and any revision, and a result can be cited by hash.

**What conformance checks.** Against this substrate PromptABI verifies the behaviours that break portable clients in practice: streaming chunk order (role first, content deltas in index order, `finish_reason` only last) with deterministic reassembly under benign reordering; context-window semantics per provider revision, proving whether a planned request fits a shared or split token budget and diffing two revisions for silent shrinkage; error-envelope compatibility, including HTTP-status/error-type agreement; native grammar-backend feature compatibility with an alternative-backend suggestion; multi-turn and parallel tool-call accounting, including cancellation semantics (every emitted call is answered or explicitly cancelled, never silently dropped); structured- output refusal envelopes, so a refusal is never mis-parsed as data; and stop- policy equivalence across providers, proving two policies truncate the same candidate at the same index.

**From evidence to release decisions.** Conformance is continuous, not a one-time pass. Signed fixture-provenance attestations bind each captured response to a signer and a provider revision and detect tampering or staleness. A benchmark-drift dashboard turns a series of runs into a pass-rate trend with regression and recovery findings and an alarm when the rate falls below the best- ever baseline. Failures render into standardized, de-duplicated issue templates with stable fingerprints. Capability negotiation resolves required features against a provider’s support and declared fallbacks before a request is sent, and provider-migration dry-runs compute the exact rename/clamp/drop patch—flagging every lossy step—needed to move a request between providers. A deployment gate binds this evidence to policy (minimum pass-rate, required obligations, severity ceiling, revision allow/deny) and emits a promote/block decision with precise reasons, the bridge from conformance evidence to release automation. A language-neutral contract IR lets SDK readers in any language consume the same contract, and an annual provider-semantics report and a shared standards proposal (a normative, clause-identified checklist scored per provider) turn the whole layer into a citable, governance-ready artifact.

## 20 Benchlines and Experiments

PromptABI’s repository includes several benchlines, each serving a different claim.

**Smoke performance.** `benchmarks/benchmark_smoke.py` measures representative local checks: tokenizer analysis, grammar emptiness, stop checks, SMT-backed static contracts, budget checks, and corpus-wide verification. The goal is not GPU throughput; it is whether static verification is cheap enough to run before merge.

**Incremental-cache proof tests.** `tests/test_incremental_verification.py` exercises real incremental plans, cache reuse, stale-key rejection, and the public proof-sketch API. The same certificate fields are emitted in JSON diagnostics, so CI evidence contains the exact dependency cut and cache fingerprint that justified reuse.

**Real-bug benchmark.** `promptabi corpus real-bug-benchmark` loads labeled real-world bug records and verifies source hashes, upstream references, and expected diagnostic families. The production-code replay benchmark additionally checks merged upstream bugfix PRs against pre-fix source excerpts and removed lines.

**Adversarial corpus.** `promptabi corpus adversarial` generates and replays cases for role delimiters, special tokens, Unicode normalization, JSON escaping, markdown fences, XML-ish tool tags, and provider envelopes. This is a stress suite for interface boundaries, not a model attack benchmark.

**Evaluation corpus.** `promptabi corpus evaluation` scores labeled cases from `fixtures/evaluation/labeled_corpus.json`. The output reports precision, recall-like agreement, abstention behavior, and witness quality on known safe/unsafe/unsupported cases.

**Conformance suites.** Grammar-backend, tokenizer-family, provider-fixture, and framework-truncation conformance suites compare PromptABI abstractions to real or fixture-backed library behavior. These suites defend against abstraction drift: if the checker no longer matches the deployed library fragment, it should fail or abstain.

**Solver-trust benchlines.** A dedicated family of tests certifies the decision procedure itself. `tests/test_minimal_encodings.py` mechanizes the smallest verdict-bearing encoding of every supported construct on both backends; the solver-fragment conformance suite labels satisfiable, unsatisfiable, and out-of-fragment instances and fails on any verdict or classification mismatch; `tests/test_solver_portfolio_replay.py` proves cross-strategy agreement and bit-for-bit replay determinism; the proof-carrying cache tests reject tampered SAT models and UNSAT cores on reuse; and `tests/test_timeout_degradation.py` profiles a timeout ladder and asserts that no conclusive verdict under a tight budget contradicts the generous-budget ground truth. These are unit cells of the soundness argument rather than performance numbers.

**Unicode and cross-field decision benchlines.** `tests/test_unicode_normalization.py` models NFC/NFKC normalization of a finite alphabet, cross-validates the “already normalized” set against the finite solver, and detects confusables and non-idempotent forms; the cross-field obligation tests prove consistency and entailment of multi-field JSON-schema obligations (ordering, mutual exclusion, sum bounds, required-if) that a property-at-a-time validator cannot express.

**Maintainer refresh.**

**Corpus release gate.** `promptabi corpus verify` runs the maintained seed, structured-schema, provider-fixture, conformance, real-bug, evaluation, and SMT benchmark gates with release-blocking thresholds.

**Maintainer refresh.** `promptabi maintain refresh` updates corpus summaries, expected diagnostics, provider fixtures, release notes, and benchmark metadata. It makes evaluation maintenance reproducible rather than relying on informal manual updates.

**Roadmap and evidence reports.** `promptabi roadmap trends` converts dashboard history into structural-risk trend reports across repositories, teams, model families, provider migrations, and fine-tuning pipelines. `promptabi roadmap corpus-refresh` emits a read-only annual refresh procedure that can retire obsolete artifacts, add model families, update provider semantics, and preserve old benchmarks without destroying longitudinal evidence. `promptabi roadmap award` builds a concise award-submission brief from comparative studies, real-bug benchmarks, conference demos, and leaderboards, so claims remain evidence-bound rather than marketing copy. `promptabi roadmap teaching` turns executable examples and proof notebooks into university and internal-training labs. `promptabi roadmap research-agenda` publishes the next hundred compositional-verification, solver, prompt-pack, training-contract, and provider-standard conformance goals.

| Workflow              | Evidence source                                     | Output                                             |
|-----------------------|-----------------------------------------------------|----------------------------------------------------|
| Historical trends     | dashboard JSONL, corpus manifests                   | team/model/provider risk movement                  |
| Annual corpus refresh | seed, structured-schema, provider, real-bug corpora | read-only retirement and preservation plan         |
| Award brief           | comparative study, demos, leaderboard               | concise claims, limitations, reproduction commands |
| Teaching materials    | examples, proof notebooks, concept docs             | five-module syllabus and executable labs           |
| Research agenda       | maintained roadmap generator                        | next 100 tracked research steps                    |

Table 5: Roadmap reports convert repository evidence into maintainable external artifacts.

| Study (roadmap step)            | Metric                        | Result               |
|---------------------------------|-------------------------------|----------------------|
| Corpus (316)                    | labeled configurations        | 10,080               |
| Role-confusion prevalence (317) | ground-truth / predicted      | 21.1%/25.8%          |
| Schema violations (318)         | curated-corpus rate           | 0.40                 |
| Longitudinal drift (319)        | max month-over-month          | 0.043 (in band)      |
| Inter-rater (320)               | Cohen’s $\kappa$              | 0.87                 |
| Role-boundary $P/R/F_1$ (321)   | precision/recall/ $F_1$       | 0.82/1.00/0.90       |
| Ablation (322)                  | sanitizer-pass precision gain | +0.61                |
| Throughput (323)                | byte-level round trip         | 1M tok, exact        |
| Fuzzing (324)                   | introduced violations         | 34 across 8 surfaces |
| Leaderboard (325)               | families ranked / all sound   | 9/9                  |
| CVE regressions (326)           | detected                      | 3/3                  |
| False-positive cost (327)       | false-discovery rate          | 0.18                 |
| Cross-tokenizer (328)           | multilingual alignment error  | 0.00 (14 locales)    |
| Training contracts (329)        | violation rate                | 0.00                 |

Table 6: Scaled empirical evaluation. Every cell is produced by replaying the production analyzers over the generated corpus; the harness reproduces them deterministically against a golden file.

## 21 Scaled Empirical Evaluation

The benchlines above certify individual mechanisms; this section measures the verifier as a whole at corpus scale. The driver is `promptabi scaled-eval` (module `promptabi.scaled_evaluation`, reproduced one-command by `benchmarks/scaled_eval_repro.py` against a checked-in golden summary). Everything is CPU-only, network-free, and seedless-deterministic: re-running the harness reproduces every number bit-for-bit.

**Corpus construction (labels independent of the tool).** We synthesize **10,080** labeled chat-template configurations over the *real special-token vocabularies* of the nine open-repository-derived seed families in `fixtures/seed_corpus` (Llama-3, Mistral, Qwen, Gemma, Phi, Zephyr, ChatML, DeepSeek, and an OpenAI-compatible surface). Each case fixes a family, an injection surface, a locale, a turn count, and one field-handling strategy. Ground truth is assigned *by construction*, independently of the analyzer under test: a template that interpolates the role/content fields *raw* can render a control delimiter inside a role region and is therefore genuinely VULNERABLE; a template that routes every untrusted field through a delimiter-neutralizing filter (`tojson`, `escape`, `urlencode`, `base64`) cannot and is SAFE; and a template that strips the delimiters with an *unmodeled* `replace` chain is also genuinely SAFE. Because the analyzer’s prediction depends only on (family, strategy), the full corpus is covered with  $\leq 63$  memoized analyzer invocations in roughly three seconds.

**Soundness with characterized incompleteness (RQ: precision/recall).** Replaying the production role-boundary analyzer over the corpus yields *recall 1.0 with zero false negatives*: every constructed vulnerability is caught. Precision is 0.82 and  $F_1 = 0.90$ ; crucially, *all* false positives belong to the single **strip-replace** class, i.e. conservative over-warnings on a sanitizer the abstraction deliberately does not model. This is exactly the behavior a sound-but-incomplete verifier should exhibit, and it is measured rather than asserted (Table 6).

**Marginal value of a pass (ablation).** Disabling the sanitizer-recognition pass collapses the analyzer to the conservative baseline that flags every raw delimiter site, dropping precision from 0.82 to 0.21 at unchanged recall: the pass contributes +0.61 precision. This isolates the empirical payoff of a single design choice.

**An independent second rater (inter-rater study).** A second oracle that never runs the analyzer—it rules a template safe iff every field passes through a recognized neutralizing filter—agrees with the tool on 95.3% of cases, Cohen’s  $\kappa = 0.87$ . The disagreements are confined to the **strip-replace** class, quantifying exactly where a human reviewer and the conservative checker diverge.

**Drift, throughput, and breadth.** Grouping the corpus into twelve monthly provider revisions, predicted role-confusion prevalence stays within a 0.043 month-over-month band. The byte-level tokenizer round-trips a one-million-token payload exactly, and the symbolic role analyzer processes a 200k-character literal in tens of

| Capability (roadmap step)        | Mechanism                | Result                            |
|----------------------------------|--------------------------|-----------------------------------|
| Provider adapters (331)          | fixture-pack replay      | 3 families, deterministic         |
| Signed snapshots (332)           | keyed SHA-256 digest     | tamper-evident                    |
| GH Action / pre-commit (333,336) | emitted CI assets        | SARIF upload wired                |
| Drift dashboard (334)            | 12 monthly revisions     | regression @ 2025-06              |
| SARIF gate (335)                 | SARIF 2.1.0              | exit 0 clean / $\neq$ 0 regressed |
| Grammar backend bench (337)      | real feature checker     | coverage 0.50, 8 rows             |
| HTTP cassettes (338)             | deterministic replay     | 6 cassettes, stable hashes        |
| OTel export (339)                | spans + attributes       | schema-valid                      |
| Regression bisector (342)        | snapshot bisection       | first-bad 2025-06                 |
| Cost-aware sampling (343)        | budgeted selection       | budget honored                    |
| Webhook alarm (344)              | regression event         | triggered                         |
| Gateway certification (345)      | request/response replays | 3/3 certified                     |

Table 7: Continuous conformance layer. Each row is produced by a real run of `promptabi ci` over the offline provider fixture packs; the synthetic 2025-06 regression exercises the detection, bisection, and alarm paths.

milliseconds. A multilingual cross-tokenizer study over fourteen locales reports zero alignment error, the mutation-fuzzing campaign introduces 34 contract violations across eight surfaces, and three reproduced prompt-injection CVE-style vectors are all detected. All nine families are ranked on a conformance leaderboard and every one is certified sound (no false negatives).

**Honesty of the numbers.** We emphasize that the headline precision is deliberately *not* 1.0: a verification tool that reports recall 1.0 on a construction where the labels are independent of the tool, while attributing every residual false positive to a named, fixable unmodeled-filter class, is a more trustworthy artifact than one tuned to a flattering aggregate. The same harness that prints these numbers gates regressions against the committed golden summary.

## 22 Live Provider Integration and Continuous Conformance

Static soundness is necessary but not sufficient for a tool that must track a *moving* ecosystem of provider APIs. This section describes the continuous conformance layer (`promptabi ci`, module `promptabi.live_provider_ci`) that turns PromptABI’s checks into a signed, replayable, drift-tracking CI gate. As with everything else in the artifact it is CPU-only and network-free: “live” providers are modeled by the checked-in provider fixture packs (Anthropic, Bedrock, Gemini, LiteLLM, OpenAI, and a vLLM OpenAI-compatible server), so every run is bit-for-bit reproducible and yet exercises the same request/response/tool-call surfaces a real adapter would.

**Replayable adapters and signed snapshots.** Three provider adapters (an OpenAI surface, an Anthropic surface, and an OSS vLLM surface) are reconstructed from their fixture packs and executed deterministically; each adapter is tool-call-aware, so issuing a request with a tool list flips the modeled finish reason and changes the response hash. A run captures a *snapshot*—provider families, per-surface pass map, manifest and replay hashes—that is signed with a SHA-256 keyed digest over its canonical JSON. Tampering with any field invalidates the signature, giving a tamper-evident audit record suitable for supply-chain attestation.

**Longitudinal dashboard, bisection, and alarms.** Twelve monthly revisions are tracked on a drift dashboard. We inject a synthetic regression at revision 2025-06 (one surface flag flipped and re-signed) and confirm the full incident-response chain fires end to end: the dashboard flags the month with a maximum drift of 0.143, a snapshot bisector pinpoints 2025-06 as the first bad revision, a PR-comment diff renders the exact regressed surfaces, and a webhook alarm emits a `promptabi.conformance.regression` payload (Table 7). A clean latest snapshot exits 0; a regressed snapshot produces SARIF findings and a non-zero gate.

**Backend feature benchmarking and third-party gateways.** The grammar-backend bench runs the real feature checker against the vLLM and TGI backends over eight constrained-decoding features; unsupported features (e.g. unbounded recursion) are reported rather than silently accepted, yielding a coverage of 0.50. Six HTTP cassettes record and deterministically replay the provider surfaces, and three third-party gateways are certified by replaying their request/response pairs (3/3). The same report renders to text, JSON, and OpenTelemetry



| Surface (roadmap step)  | Artifact                            | Verification           |
|-------------------------|-------------------------------------|------------------------|
| Language server (346)   | LSP <code>publishDiagnostics</code> | 15 real diagnostics    |
| VS Code extension (347) | <code>package.json</code> + client  | schema-valid           |
| SDK readers (348)       | Py/TS/Go/Rust                       | Python round-trips     |
| Explanation (349)       | tutorial-style text                 | rendered from finding  |
| Autofix (350)           | ranked suggestions                  | 13 fixes               |
| JSON Schema (351)       | Draft 2020-12                       | 3 object schemas       |
| WASM playground (352)   | Pyodide HTML                        | browser-resident       |
| Quickstart (353)        | one-call bug find                   | error in <1 s          |
| Plugin API (354)        | 3rd-party analyzer                  | runs in real scheduler |
| Framework shims (355)   | LangChain/LlamaIndex/DSPy           | valid Python           |
| Typed stubs (356)       | <code>.pyi</code>                   | AST-valid              |
| i18n (357)              | message catalog                     | 5 locales              |
| Tutorial notebook (358) | <code>nbformat</code> 4             | JSON-serializable      |
| Policy profiles (359)   | org severity/gate overrides         | strict/lenient         |
| Coverage badge (360)    | SVG                                 | ≥90% green             |

Table 8: Developer-experience and ecosystem surfaces. Each artifact is produced from real `run_verification` output over the bundled RAG example and validated structurally (valid JSON/AST/SVG, importable readers, schema-conformant diagnostics).

spans, and the SARIF output integrates directly with the emitted GitHub Action and pre-commit hook so that any conformance regression blocks a merge with an actionable, code-scanning-native finding.

## 23 Developer Experience and Ecosystem

A verifier is adopted only if it meets developers where they already work. This section describes the ecosystem layer (`promptabi devex`, module `promptabi.devex_ecosystem`) that projects PromptABI’s results onto the fifteen surfaces a production tool is expected to provide. Crucially, every surface is constructed from *real* verifier output: the layer runs the production `run_verification` over the bundled `examples/rag-chunking` project—which emits genuine error-severity contract violations (`rag-citation-loss`, `rag-payload-truncation`, and a closed-tool schema violation)—and builds each artifact from those findings.

**Editor and language tooling.** Findings are emitted as a Language Server Protocol `textDocument/publishDiagnostics` notification (severity, range, rule-id code, and fix data per diagnostic) together with an `initialize` capability advertisement, and a VS Code extension scaffold (a schema-valid `package.json` plus a language-client `extension.js`) wires the server into the editor with inline prompt-safety hints. Each finding is expanded into a tutorial-style explanation (what invariant failed, which proof modes applied, the likely runtime symptom) and ranked, blast-radius-annotated autofix suggestions.

**Interoperability and onboarding.** PromptABI publishes stable JSON Schemas (Draft 2020-12) for its `SourceSpan`, `Diagnostic`, and `VerificationResult` objects, and *generates* result readers in four languages—Python, TypeScript, Go, and Rust—directly from those object shapes; the generated Python reader is exercised in CI by round-tripping a real diagnostic. A Pyodide/WASM playground runs the verifier entirely in the browser, a sub-five-minute quickstart finds a genuine error-severity bug in a single call, and a runnable `nbformat-4` tutorial notebook reproduces the workflow. Framework integration shims for LangChain, LlamaIndex, and DSPy gate live chains on contract conformance (Table 8).

**Extensibility and governance.** A third-party analyzer (a banned-override-phrase check) is registered on a `PluginRegistry` and executed end-to-end by the production scheduler via `selected_checks`, demonstrating that external analyzers contribute diagnostics through the same pipeline as built-in checks. An organization policy/profile system applies per-rule severity overrides, rule disables, and a configurable failure threshold (e.g. a `strict` profile that gates on warnings versus a `lenient` profile that downgrades unpinned-artifact findings to informational), internationalized finding messages cover five locales, and a coverage badge renders the suite’s high branch coverage as a shields-style SVG. Together these surfaces turn a sound static checker into an adoptable ecosystem component without sacrificing determinism or its CPU-only, offline guarantees.

| Capability (roadmap step)      | Analyzer         | Result                              |
|--------------------------------|------------------|-------------------------------------|
| Attack taxonomy (361)          | six analyzers    | all detectable                      |
| Differential harness (362)     | role-boundary    | 9/9 raw caught, 9/9 hardened safe   |
| Disclosure record (363)        | role-boundary    | reproduced advisory                 |
| Template injection (364)       | role-boundary    | 9 forgeable raw families            |
| Tokenizer smuggling (365)      | round-trip       | marker survives; escape neutralizes |
| Homoglyph control (366)        | confusable fold  | disguised tokens flagged            |
| Hardened library (367)         | role-boundary    | 9 families <i>proven</i> safe       |
| CTF benchmark (368)            | role-boundary    | 5/5 sound, no false negatives       |
| Defense coverage (369)         | taxonomy         | 1.00                                |
| Supply-chain attestation (370) | keyed digest     | signed + tamper-evident             |
| Refusal confusion (371)        | refusal envelope | ambiguous bypass flagged            |
| Multi-agent confusion (372)    | handoff analyzer | 4 violations                        |
| Streaming desync (373)         | parser product   | desync over split chunks            |

Table 9: Security and red-team research surfaces. Each result is produced by a real PromptABI analyzer over fixtures or constructed adversarial vectors.

## 24 Security and Red-Team Research

PromptABI is, at its core, a defensive security tool, and this section turns its analyzers into an offensive research artifact (`promptabi red-team`, module `promptabi.red_team_research`). Every detection below is produced by running a *real* analyzer over real fixtures or constructed adversarial vectors; the layer is CPU-only, offline, and deterministic.

**Attack taxonomy and cross-provider differential.** We catalog six prompt-interface attack classes—role-boundary forgery, tokenizer-boundary control-token smuggling, unicode-homoglyph control impersonation, refusal-channel confusion, multi-agent tool-call confusion, and streaming-parser desynchronization—and prove each one detectable by a named analyzer. A differential harness replays the role-boundary analyzer over all nine seed provider families: every raw-interpolation template is flagged (*zero false negatives*) and every hardened (`tojson`) template is cleared, isolating the vulnerability to the field-handling strategy rather than the provider (Table 9).

**Detectors, a proven hardened library, and a CTF.** Dedicated detectors confirm that a special-token marker survives a naive byte-level tokenizer round trip (smuggling) while an escaping defense neutralizes it, and that unicode-homoglyph and confusable impersonations of control-token fragments (e.g. fullwidth and Cyrillic look-alikes of `<|im_start|>`) are caught by NFKC-folding without flagging benign ASCII text. We then ship a *hardened reference prompt-assembly library* and *prove* it unforgeable: the role-boundary analyzer certifies its emitted template as safe across all nine families. An escalating CTF benchmark of five injection challenges is solved soundly (every genuinely vulnerable level is flagged), and a defense-in-depth measurement reports full taxonomy coverage.

**Confusion attacks, supply chain, and disclosure.** The real refusal classifier flags refusal-channel confusion (an empty parsed payload with no refusal channel), the multi-agent handoff analyzer reports four tool-call confusion violations on a real manifest, and the streaming parser product detects desynchronization when a tool-call JSON is split across stream chunks. Prompt packs are attested with a keyed digest that is verifiable and tamper-evident, and the layer emits a security whitepaper with an attack taxonomy and a coordinated-disclosure timeline plus a responsible-disclosure policy and contact. The result is a research-grade offensive complement to the defensive verifier, with every claim backed by an executable, deterministic analyzer run.

A PromptABI diagnostic is designed to answer five questions in one artifact: what invariant failed, where the source of the invariant lives, which semantic mode was used, what witness demonstrates the issue, and what low-blast-radius fix is plausible. The diagnostic model includes severity, source span, artifact provenance, check modes, fingerprint, suggestions, witness trace, and optional upstream issue links.

Witnesses are deliberately concrete. A role-boundary witness contains the attacker-controlled field, rendered excerpt, token evidence, and forged boundary. A stop witness contains the stop, valid full output, returned prefix, and parser state. A budget witness contains token counts, truncation decisions, and dropped required segments. A multi-agent handoff witness contains the source agent, target agent, payload role, missing field or bad type, and

offending rendered payload excerpt. An SMT witness contains a finite assignment or unsat evidence. This makes diagnostics actionable for engineers and replayable for maintainers.

PromptABI also includes witness validation, shrinking, and slicing. Counterexamples can be minimized by string length, token count, message count, schema size, or rule complexity; multi-artifact products can be sliced to the cheapest set of template/tokenizer/provider/policy artifacts that still explains the failed facts. The upstream bug-report generator then turns the minimized repro into a sanitized issue with artifact versions, reproduction commands, expected/actual behavior, and non-sensitive traces.

## 25 Versioning, Drift, and Lockfiles

LLM interface artifacts drift. Tokenizer IDs change, added tokens appear, normalizers shift, chat templates acquire generation prompts, provider envelopes change, stop policies move from framework defaults to provider overrides, and dataset preprocessing pipelines get rebuilt with new library versions. PromptABI treats these changes as contract events.

Lockfiles pin artifact hashes, upstream revisions, library versions, provider fixture versions, supported fragments, and diagnostic baselines. The `promptabi diff` workflow compares configurations and reports contract-breaking changes with witnesses. The `promptabi version-gate` workflow lets teams declare whether a change is patch-safe, minor-breaking, or major-breaking for a deployment.

Regression bisection then identifies the exact artifact update that introduced a failure. Maintainers can bisect tokenizer, template, schema, provider, or framework revisions without running a model. This makes PromptABI useful not only for initial verification but for long-lived production systems that upgrade their surrounding LLM software weekly.

## 26 Static Contract Language

Beyond built-in checks, PromptABI includes a static contract language for declaring allowed roles, required regions, forbidden delimiters, schema obligations, stop policies, solver-backed invariants, and cross-artifact assume/guarantee facts. The language can be formatted, linted, migrated, and composed across organization policies, prompt packs, app configs, RAG systems, fine-tuning datasets, and eval harnesses.

The compiler lowers rules to the same verification backends used elsewhere: automata products, SMT formulas, differential checks, and diagnostics with source spans. Composition is explicit about precedence. Assume/guarantee clauses make dependencies reviewable: an app rule can assume that a tokenizer preserves a control-token contract or that a schema preserves a tool-call shape, and the verifier discharges that assumption only when a loaded provider artifact or artifact kind declares the matching guarantee. Linting catches impossible rules, vacuous guarantees, unsupported fragments, unresolved assumptions, contradictory policies, and overly broad suppressions. Migration explains behavior changes when rule syntax or solver-backed semantics evolve.

This is important because production teams rarely want only built-in checks. They want local invariants: “this system message must survive,” “these tool names are the only allowed tools,” “user text must not enter assistant loss,” or “this provider migration cannot change argument encoding.” Static contracts make those policies versioned and reviewable.

## 27 Governance and Community Infrastructure

PromptABI includes contribution and governance machinery because verification tools fail when corpora, proofs, and supported fragments are informal. Governance docs specify checker acceptance criteria, proof standards, corpus licensing, security disclosures, and release-blocking regressions. Maintainer health checks cover triage labels, release checklists, corpus review procedures, rotation docs, and long-term project metrics.

Community workflows accept sanitized bug fixtures, minimized witnesses, prompt-pack metadata, provider fixtures, and training-manifest adapters. Plugin certification tests check that third-party loaders, renderers, providers, and solver encodings preserve diagnostic and privacy contracts. A marketplace-style index records plugin capabilities, supported fragments, privacy behavior, version compatibility, and verification status.

## 28 Why Static Interface Verification Is Distinct

PromptABI occupies a narrow but valuable point in the LLM tooling space. It does not compete with model evals, red-team prompts, jailbreak classifiers, or semantic safety policies. Those tools ask what a model might do. PromptABI asks whether the deterministic interface surrounding the model is internally consistent before the model acts.

The distinction creates practical advantages. The verifier is CPU-only, so it can run in every pull request. It is version-aware, so a dependency update can be gated. It is source-mapped, so a diagnostic points to the artifact that created the contract. It is privacy-preserving, so teams can share hashes and structural witnesses without sharing prompts. And it is honest about supported fragments, so unsupported cases become visible engineering work rather than silent false proofs.

## 29 Evaluation Design

PromptABI’s evaluation separates verifier-maintenance tests from real-world claims. Unit tests, property tests, and small local fixtures are useful for maintaining the implementation, but they are not counted here as bug-finding evidence. The evaluation in this paper counts only public upstream code that was shipped in the wild and is pinned by repository, commit, path, license, and SHA-256 hash.

### 29.1 Research Questions

The evaluation asks four questions.

1. **Bug finding on real code:** when given exact production artifacts from public incidents, does PromptABI find the interface bug?
2. **Attribution:** does the diagnostic identify the production artifact and boundary responsible for the bug?
3. **Replayability:** can the result be rerun offline from pinned public source bytes and upstream bug records without model weights, provider calls, or private data?
4. **Cost:** is the check cheap enough for CI?

### 29.2 GitHub Bug Search and Corpus

We searched public GitHub issues and pull requests in llama.cpp, vLLM, and Hugging Face Transformers for recorded failures involving chat templates, role delimiters, tool parsers, stop strings, quote sentinels, streaming parser state, and structured-output boundaries. That search identified dozens of PromptABI-class records, but a record is admitted to the strict analyzer evaluation only if the issue or PR names an upstream production artifact and PromptABI can recover the relevant boundary from exact pinned source bytes. Six records meet that bar in the current corpus. Records that require hand-reduced payloads, live model sampling, or a verifier family not yet implemented are excluded from the strict analyzer count.

To answer the scale question separately, we also mined merged upstream bugfix PRs and admitted only cases where the PR base commit, production file, and bugfix patch agree: the exact source excerpt at the base commit must contain source line(s) removed by the upstream fix. This creates a larger source-and-patch replay benchmark of real production bugs. It is deliberately reported separately from the PromptABI-specific analyzer result: it measures whether the benchmark is operating on real code and real upstream bug records, not whether every bug belongs to PromptABI’s current verifier families.

Table 10 lists the strict PromptABI analyzer corpus. Each row is exact code in the wild. The tool loads the pinned source excerpt, validates the source hash, extracts the template, parser delimiter, parser regex, or parser control-flow pattern from those bytes, and only then runs the checker. If the expected value cannot be recovered from the source, the replay fails.

### 29.3 Results

PromptABI agrees with all six GitHub-recorded bugs in the strict analyzer corpus. The Gemma4 quote case finds the exact production parser pattern described in vLLM issue #39069: `_ESCAPE_TOKEN` is replaced with a raw quote, then fallback parsing uses a regex fragment that stops at the first internal quote. The Gemma4 streaming case finds the source pattern from issue #38910 and PR #38909: buffered delta text is reconstructed into the parser’s accumulated input. The llama.cpp `TAG_WITH_TAGGED` case finds the source branch described in issue #21771, where non-string tagged parameters enter `p.json()` inside the tag grammar. The Phi case yields 18 role-boundary witnesses after traversing 430 bytes of the exact upstream template. The Qwen3 Coder case yields 2 stop-overreach witnesses after extracting `</tool_call>`, `</function>`, and `</parameter>` from exact upstream parser source. The Qwen3 XML case finds the stale function-state pattern from issue #43713.

The larger replay benchmark contains 66 exact upstream production-code cases: the six strict analyzer cases plus 60 merged upstream vLLM bugfix PRs admitted by source-and-patch agreement. For those 60 scale cases, PromptABI validates the PR URL, merged state, base commit, production source path, source excerpt hash, and that the exact line(s) removed by the upstream bugfix are present in the pinned pre-fix source excerpt. The 60 scale cases cover 90 upstream-removed source lines. On a local CPU run, the complete replay command finishes in 0.75 seconds wall-clock time.



| Production artifact                                                              | Public incident                                                                                     | Property checked                                                                                                             | Result                                     |
|----------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------|
| vLLM <code>gemma4_utils.py</code> at commit 6a11d72                              | Issue #39069: internal quotes truncate Gemma4 tool arguments                                        | Does source replace the Gemma quote sentinel with " and then parse with a quote-stopping fallback regex?                     | Bug found: parser truncation pattern       |
| vLLM <code>gemma4_tool_parser.py</code> before PR #38909                         | Issue #38910: streamed HTML tags duplicated inside tool arguments                                   | Does streaming buffer output get stitched back into the accumulated parser input?                                            | Bug found: buffer reparse pattern          |
| llama.cpp <code>chat-auto-parser-generator.cpp</code> at commit 2016bf2          | Issue #21771: Qwen3 <code>Tag_WITH_TAGGED</code> array-of-object arguments poison streaming history | Does the non-string tagged-parameter branch route structured arguments through <code>p.json()</code> inside the tag grammar? | Bug found: JSON-parameter boundary pattern |
| llama.cpp <code>microsoft-Phi-3.5-mini-instruct.hugging</code> at commit 2016bf2 | PR #18462: Phi-style role delimiters handling                                                       | Can raw message content forge role/special-token boundaries?                                                                 | Bug found: 18 role-boundary witnesses      |
| vLLM <code>qwen3coder_tool_parser.py</code> at commit 6a11d72                    | PR #40861: Qwen3 XML tool parser regressions                                                        | Can parser stop delimiters occur inside a valid tool argument boundary?                                                      | Bug found: 2 stop-overreach witnesses      |
| vLLM <code>qwen3xml_tool_parser.py</code> at commit 6a11d72                      | Issue #43713: multiple <code>&lt;function=...&gt;</code> blocks emit invalid JSON                   | Does function-open auto-close reuse stale function state without a fresh tool-call boundary?                                 | Bug found: stale function-state pattern    |

Table 10: Strict PromptABI analyzer cases. Every case is replayed from exact pinned upstream production code; synthetic reductions are not counted.

## 29.4 Interpretation

The evaluation has two claims, kept separate. The strict claim is that for the six PromptABI analyzer cases, PromptABI traverses the same public code that shipped upstream, recovers the relevant boundary from that code, and produces concrete diagnostics before inference. The scale claim is that the benchmark can also replay more than 50 real production bugfixes without synthetic reductions: each scale case is tied to a merged upstream PR, a pre-fix production source file, an exact source hash, and source lines removed by the upstream fix. We do not count those 60 scale cases as additional PromptABI boundary bugs unless a PromptABI verifier family actually analyzes them.

## 30 Confirming New Upstream Bugs

The benchmarks of Section 29 replay *already known* upstream incidents. A harder, higher-value question is whether the same analyzers can be driven as a disciplined campaign to surface a *new* interface-safety bug in live upstream code, triage it honestly, and route it to a responsible report. PromptABI ships this campaign as a first-class, auditable engine (`promptabi upstream-bug-campaign`) rather than an ad hoc bug hunt.

**Methodology as the artifact.** The campaign fixes its scope before searching: it defines the target outcome as a maintainer-confirmed interface bug, enumerates the admissible bug classes (role-boundary forgery, delimiter leakage, parser boundary confusion, tool-call corruption, malformed structured output, unsafe stop behavior, reasoning/tool boundary loss, response-shape violation), and excludes model-quality, hallucination, performance, and hardware regressions. It then selects active upstream targets (vLLM, llama.cpp, Hugging Face Transformers by default), records each project’s branch, release, contribution guide, and security policy, and pins every scanned file by repository, commit SHA, public URL, license, and content hash. A library of *flag rules* encodes the structural smells of each bug class (e.g. a template that renders content adjacent to role headers, a parser that reuses a tool-call index across function blocks, or a reasoning parser that decides the reasoning/content transition from token-id membership alone).

**A flag is only a candidate.** The defining property of the campaign is its conservatism: a structural flag, or a substring match, is never a bug. Each candidate carries a one-sentence contract-violation claim, the expected and

| Metric                                          | Value |
|-------------------------------------------------|-------|
| Exact upstream production-code cases            | 66    |
| Strict PromptABI analyzer cases                 | 6     |
| Strict cases with expected bug found            | 6     |
| Merged upstream bugfix replay cases             | 60    |
| Bugfix replay cases with patch/source agreement | 60    |
| Abstentions in strict analyzer cases            | 0     |
| Model or provider calls                         | 0     |
| Strict witnesses/pattern agreements             | 30    |
| Upstream-removed source lines replayed          | 90    |
| Wall-clock runtime                              | 0.75s |

Table 11: Current production-code evaluation results.

actual behavior, a duplicate search, a minimal offline reproduction plan, and a disclosure route, and is then driven through deterministic PromptABI analysis of the *exact pinned source* before any claim is permitted. The engine re-verifies every captured file against its recorded hash on each run and emits one of four honest outcomes per candidate: **confirmed** (the analyzer deterministically reproduces a contract violation on the real code), **rejected** (the flag fires but the violation is not triggerable on the real path), **abstained** (the source lies outside a supported decidable fragment), or **duplicate** (the symptom is already tracked upstream). A candidate may be declared confirmed only when its dossier expectation matches the analyzer’s outcome; an overclaimed severity or a fabricated source hash is a hard error.

**A worked, honest scan.** A pinned scan of vLLM HEAD illustrates the discipline. The DeepSeek-R1 streaming reasoning parser decides its reasoning/content transition from `token_id` membership; the flag fires, but because `<think>/</think>` are atomic added tokens for that model the boundary cannot be forged, so the candidate is *rejected* on the real source. The Hermes tool template renders content next to role delimiters, but uses Jinja macros outside the supported fragment, so the engine *abstains* rather than guess. A streaming tool-call index-reuse symptom is recognized as a *duplicate* of an existing upstream issue, to which the campaign contributes a deterministic regression test instead of filing noise. No new bug is claimed from this particular scan—an honest result—while the run simultaneously replays public, already-confirmed exemplars (e.g. the Phi role-delimiter forgery behind llama.cpp PR #18462, recovered with dozens of witnesses) to demonstrate that the analyzer does reproduce real interface-safety bugs. The campaign thus turns “find a new bug” into a reproducible, peer-reviewable audit trail whose value does not depend on any single lucky find.

## 31 Threat Model, Limitations, and Non-Goals

PromptABI is not a model-behavior verifier. It does not prove that an LLM will answer truthfully, refuse harmful requests, or choose a tool wisely. It proves properties of the discrete interface that surrounds the model.

PromptABI is also intentionally bounded. Chat-template loops, grammar products, schema recursion, SMT domains, and context-budget facts are finite. That makes diagnostics replayable and CI-friendly, but it means claims must be read with their bounds and supported-fragment metadata.

Finally, PromptABI is not a sandbox. It avoids provider calls and model execution for verification, and it can operate on redacted evidence, but process isolation and secret governance remain deployment responsibilities.

## 32 Related Systems

PromptABI sits between several families of tools. Prompt linters and jailbreak tests look for risky strings or behavioral failures, but they do not generally compile tokenizer/template/provider artifacts into a shared semantics. Schema validators and constrained decoders help one structured-output layer, but they usually do not account for tokenizer drift, stop policies, provider envelopes, or downstream parsers. Formal methods tools can prove finite obligations, but they are rarely packaged around the artifacts LLM engineers already maintain. PromptABI’s contribution is to bring PL-style static and differential reasoning to those concrete artifacts.

### 33 Conclusion

LLM systems need a verifier for the deterministic software boundary around the model. PromptABI supplies that verifier. It treats prompt templates, tokenizers, stops, schemas, tools, providers, budgets, training manifests, and evaluation harnesses as a prompt ABI; compiles them to bounded semantics; and emits replayable proofs, counterexamples, or abstentions before inference.

The resulting workflow is practical because it is CPU-only, version-aware, source-mapped, privacy-conscious, and integrated with CI. It is credible because its diagnostics carry executable witnesses and because its real-bug evaluation traverses exact production code that shipped in the wild.